```
┌─[attacker@parrot]─[~/Downloads]
└──╼ $wget https://github.com/jgraph/drawio-desktop/releases/download/v26.2.2/drawio-amd64-26.2.2.deb
--2026-04-23 07:37:20--  https://github.com/jgraph/drawio-desktop/releases/download/v26.2.2/drawio-amd64-26.2.2.deb
Resolving github.com (github.com)... 20.207.73.82
Connecting to github.com (github.com)|20.207.73.82|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/92443980/2ebe7631-44b6-4fb8-b8a0-9007e7445
f3b?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-23T12%3A20%3A29Z&rscd=attachment%3B+filename%3Ddrawio-amd64-26.2.2.deb&rsct=appl
ication%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-04-23T11%3A
20%3A10Z&ske=2026-04-23T12%3A20%3A29Z&sks=b&skv=2018-11-09&sig=5p%2FJi%2BMwB0bHrvX%2Bra5g%2B0pbQVWqOIkLPObqKsttw4E%3D&jwt=eyJ0eXA
iOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V
5MSIsImV4cCI6MTc3Njk0NjA0MSwibmJmIjoxNzc2OTQ0MjQxLCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.gJ5MG
MfnSPzshi5_2jkjRXuAepwJ38vhMKRTisq2J0g&response-content-disposition=attachment%3B%20filename%3Ddrawio-amd64-26.2.2.deb&response-c
ontent-type=application%2Foctet-stream [following]
--2026-04-23 07:37:21--  https://release-assets.githubusercontent.com/github-production-release-asset/92443980/2ebe7631-44b6-4fb8
-b8a0-9007e7445f3b?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-23T12%3A20%3A29Z&rscd=attachment%3B+filename%3Ddrawio-amd64-26.2.
2.deb&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2
026-04-23T11%3A20%3A10Z&ske=2026-04-23T12%3A20%3A29Z&sks=b&skv=2018-11-09&sig=5p%2FJi%2BMwB0bHrvX%2Bra5g%2B0pbQVWqOIkLPObqKsttw4E
%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29t
Iiwia2V5Ijoia2V5MSIsImV4cCI6MTc3Njk0NjA0MSwibmJmIjoxNzc2OTQ0MjQxLCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93c
y5uZXQifQ.gJ5MGMfnSPzshi5_2jkjRXuAepwJ38vhMKRTisq2J0g&response-content-disposition=attachment%3B%20filename%3Ddrawio-amd64-26.2.2
.deb&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.109.133, 185.199.110.133, 185.19
9.111.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 101686194 (97M) [application/octet-stream]
Saving to: 'drawio-amd64-26.2.2.deb'

drawio-amd64-26.2.2 100%[=================>]  96.97M  3.63MB/s    in 27s

2026-04-23 07:37:49 (3.54 MB/s) - 'drawio-amd64-26.2.2.deb' saved [101686194/101686194]
```

http://localhost/booksCTF/

Parrot OS | Hack The Box | OSINT Services | Vuln DB | Privacy and Security | Learning

Index of /booksCTF

Name	Last modified	Size	Description
Parent Directory		-	
Procfile	2026-04-23 07:45	44	
README.md	2026-04-23 07:45	5.1K	
app.py	2026-04-23 07:45	15K	
requirements.txt	2026-04-23 07:45	45	
runtime.txt	2026-04-23 07:45	11	
static/	2026-04-23 07:45	-	
templates/	2026-04-23 07:45	-	

Apache/2.4.66 (Debian) Server at localhost Port 80

```
┌─[attacker@parrot]─[~]
└──╼ $cd /var/www/html
┌─[attacker@parrot]─[/var/www/html]
└──╼ $sudo git clone https://github.com/oraj25/booksCTF.git
[sudo] password for attacker:
Cloning into 'booksCTF'...
remote: Enumerating objects: 59, done.
remote: Counting objects: 100% (59/59), done.
remote: Compressing objects: 100% (47/47), done.
remote: Total 59 (delta 16), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (59/59), 2.10 MiB | 1.12 MiB/s, done.
Resolving deltas: 100% (16/16), done.
┌─[attacker@parrot]─[/var/www/html]
└──╼ $sudo systemctl start apache2
┌─[attacker@parrot]─[/var/www/html]
└──╼ $sudo systemctl start mysql
```

```
┌─[attacker@parrot]─[/var/www/html]
└──╼ $gobuster dir -u http://localhost/booksCTF -w /usr/share/wordlists/dirb/common.txt -t 50
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost/booksCTF
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 314]
/.git/HEAD            (Status: 200) [Size: 21]
/.htpasswd            (Status: 403) [Size: 314]
/.htaccess            (Status: 403) [Size: 314]
/static               (Status: 301) [Size: 356] [--> http://localhost/booksCTF/static/]
/templates            (Status: 301) [Size: 359] [--> http://localhost/booksCTF/templates/]

Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
```

```
┌─[attacker@parrot]─[/var/www/html]
└──╼ $nmap -sV -p- localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-23 07:48 EDT
Stats: 0:00:34 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 80.00% done; ETC: 07:49 (0:00:08 remaining)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00016s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 65530 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
80/tcp   open  http        Apache httpd 2.4.66 ((Debian))
3306/tcp open  mysql?
8834/tcp open  ssl/nessus-xmlrpc?
9876/tcp open  http        Apache httpd 2.4.66 ((Debian))
42069/tcp open  http       Golang net/http server
2 services unrecognized despite returning data. If you know the service/version, please submit the following fin
gerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port3306-TCP:V=7.95%I=7%D=4/23%Time=69EA070A%P=x86_64-pc-linux-gnu%r(NU
SF:LL,6C,"h\0\0\0\n11\.8\.6-MariaDB-0\+deb13u1\x20from\x20Debian\0\x20\0\0
SF:\x007l\?3#QS\+\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0\0=\0\0\0yF0\\aOIa
SF:\*N\+\)\0mysql_native_password\0")%r(GenericLines,A4,"h\0\0\0\n11\.8\.6
SF:-MariaDB-0\+deb13u1\x20from\x20Debian\0\x20\0\0\x007l\?3#QS\+\0\xfe\xff
```

```
┌─[✗]─[attacker@parrot]─[/var/www/html]
└──╼ $dirb http://localhost/booksCTF/admin

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Apr 23 08:00:44 2026
URL_BASE: http://localhost/booksCTF/admin/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://localhost/booksCTF/admin/ ----

-----------------
END_TIME: Thu Apr 23 08:00:45 2026
DOWNLOADED: 4612 - FOUND: 0
```

```
┌─[✗]─[attacker@parrot]─[/var/www/html]
└──╼ $sqlmap -u "http://localhost/booksCTF/search.php?q=book" --dbs
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.6#stable}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, s
tate and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 07:59:03 /2026-04-23/

[07:59:04] [INFO] testing connection to the target URL
[07:59:04] [CRITICAL] page not found (404)
it is not recommended to continue in this kind of cases. Do you want to quit and make sure that everything is set up properly? [Y/n] n
[07:59:13] [INFO] testing if the target URL content is stable
[07:59:13] [INFO] target URL content is stable
[07:59:13] [INFO] testing if GET parameter 'q' is dynamic
[07:59:13] [WARNING] GET parameter 'q' does not appear to be dynamic
[07:59:13] [WARNING] heuristic (basic) test shows that GET parameter 'q' might not be injectable
[07:59:13] [INFO] testing for SQL injection on GET parameter 'q'
[07:59:13] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[07:59:13] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[07:59:13] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[07:59:13] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[07:59:13] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[07:59:13] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[07:59:13] [INFO] testing 'Generic inline queries'
[07:59:13] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[07:59:13] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[07:59:13] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[07:59:13] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[07:59:13] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[07:59:13] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[07:59:13] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n]
y
[07:59:18] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[07:59:18] [WARNING] GET parameter 'q' does not seem to be injectable
[07:59:18] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If
```